

Phishing Email Investigation: A SOC Level 1 Analyst Case Study

Overview

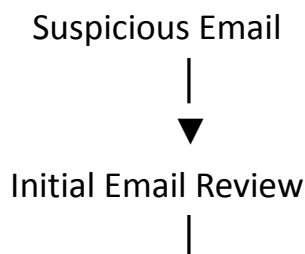
While checking my Gmail inbox, I noticed an email that had already been marked as **Spam** by Gmail. Instead of deleting it immediately, I decided to investigate it as a SOC Analyst to understand whether it was a genuine promotional email or a phishing attempt.

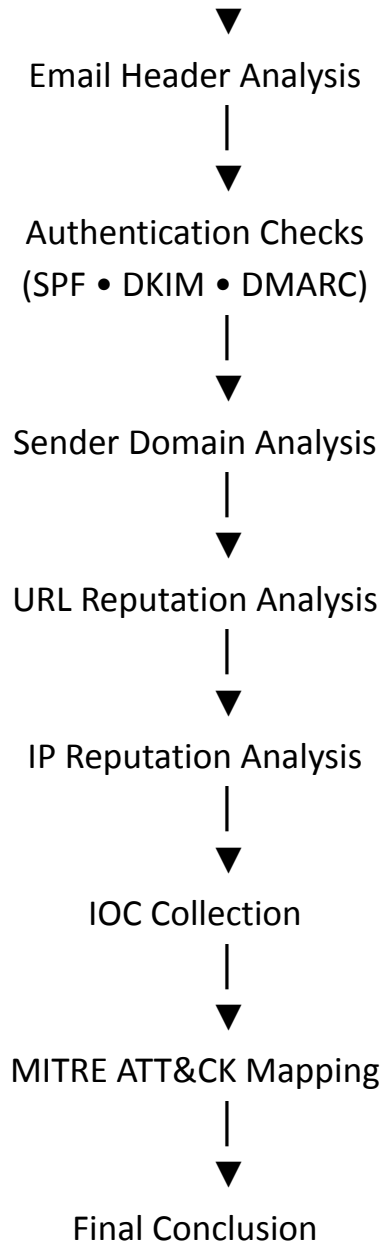
The objective of this investigation was to analyze the email headers, validate the sender, inspect authentication results, investigate the embedded URL, gather Indicators of Compromise (IOCs), and determine whether the email posed a security risk.

Tools Used

- Gmail (Email Analysis)
 - Gmail Show Original (Header Analysis)
 - VirusTotal
 - Manual Header Review
 - MITRE ATT&CK Framework
-

Investigation Workflow

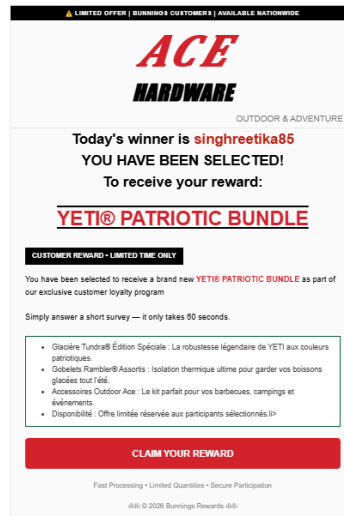




Step 1 - Initial Observation

The investigation started by reviewing the email inside Gmail without interacting with any links or buttons.

Email:



Subject

You have won a YETI PATRIOTIC Bundle

Display Name

Ace Hardware®

At first glance, the email appeared to be a promotional reward message from Ace Hardware.

However, a few things immediately caught my attention.

- Gmail had already classified it as Spam.
- The email claimed that I had won a prize even though I had never participated in any contest.
- The message contained a large "Claim Your Reward" button.
- It created urgency by encouraging immediate action.

These are common characteristics of phishing emails.

Step 2 - Email Header Analysis

Instead of trusting the display name, I opened **Show Original** in Gmail to inspect the complete email headers.

Original Message

Message ID	<h0sza3j2iq.tvhnu77wb6.1u1eobxgqk.javamail.tomcat@pdr8-services-05v.prod.0ombx67ct7.org>
Created at:	Fri, Jul 24, 2026 at 9:33 AM (Delivered after 1 second)
From:	Ace Hardware® <return@gnhmppgatace.nextapp.pp.ua>
To:	singhreetika85@gmail.com
Subject:	singhreetika85 - You have won a YETI PATRIOTIC Bundle 📦 ID#127383
SPF:	PASS with IP 45.142.115.6 Learn more
DKIM:	'FAIL' with domain gnhmppgatace.nextapp.pp.ua Learn more
DMARC:	'PASS' Learn more

The header analysis revealed the following information.

Field	Value
Display Name	Ace Hardware®
Sender Email	return@gnhmppgatace.nextapp.pp.ua
Return Path	18719-151503@648sd4f6hjk5y23.nextapp.pp.ua

Although the email claimed to be from Ace Hardware, the actual sender domain was completely different.

A legitimate marketing email from Ace Hardware would normally originate from an official company domain.

This mismatch was my first major phishing indicator.

Step 3 - Email Authentication Analysis

Next, I reviewed the email authentication results.

Authenticati on	Resul t
SPF	PASS
DKIM	FAIL
DMARC	PASS

Initially, seeing SPF and DMARC marked as **PASS** seemed reassuring.

However, after understanding how email authentication works, I realized that SPF and DMARC only validated the sender's own domain, **not the Ace Hardware brand**.

The email still impersonated Ace Hardware while using an unrelated domain.

Additionally, the **DKIM validation failed**, which reduced confidence in the authenticity of the email.

Step 4 - Social Engineering Analysis

I then inspected the email content itself.

The message relied heavily on psychological manipulation.

Examples included:

- "You have won..."

- "You have been selected."
- "Claim Your Reward"
- "Limited Time"

These techniques are commonly used to trigger excitement and urgency so that recipients act without verifying the legitimacy of the message.

No evidence suggested that I had actually participated in any reward program.

Step 5 - URL Analysis

Rather than clicking the button, I inspected the destination URL safely.

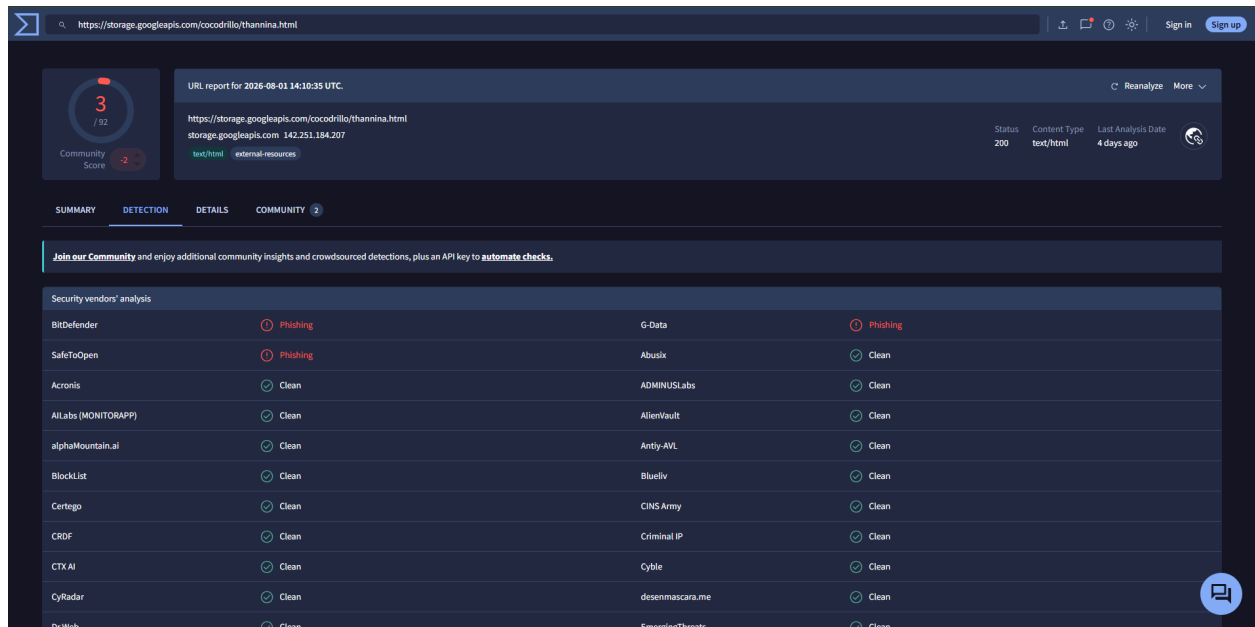
The email redirected users to:

<https://storage.googleapis.com/cocodrillo/thannina.html>

Instead of an official Ace Hardware website, the link pointed to content hosted on **Google Cloud Storage**.

Although Google Cloud Storage is a legitimate service, attackers sometimes abuse cloud hosting platforms to deliver phishing pages.

To verify this, I submitted the URL to VirusTotal.



VirusTotal Result

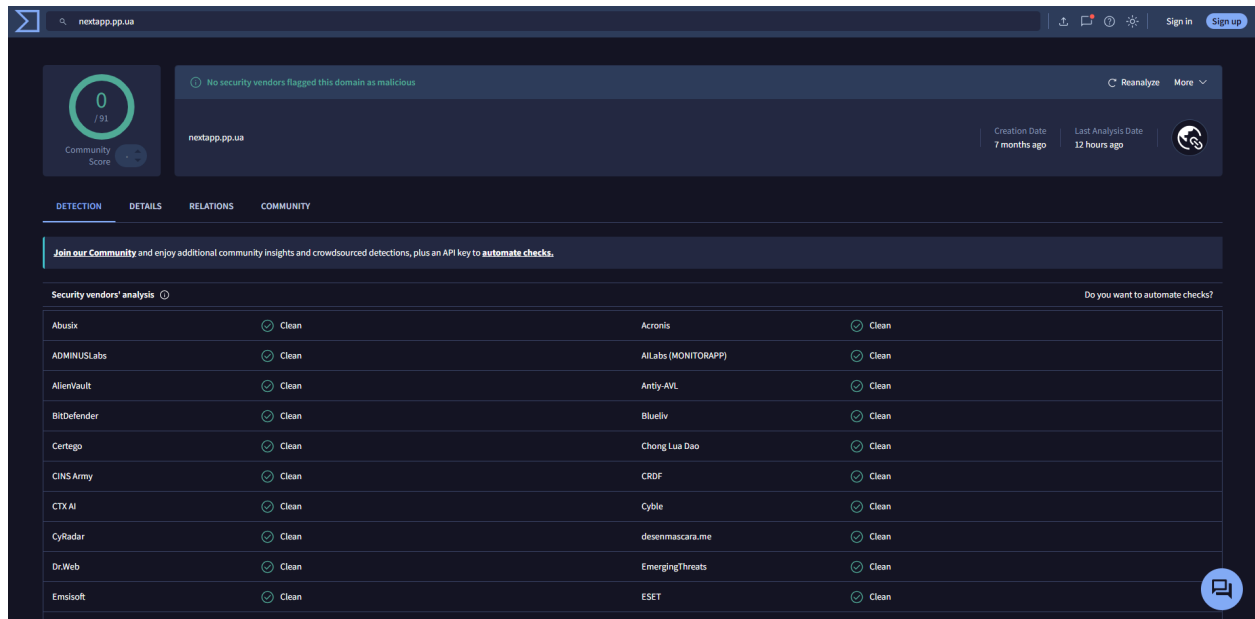
- Detection - 3 / 92 Security Vendors
- Classification - Phishing

Although only three vendors detected it as phishing, this was still an important indicator.

In SOC investigations, a low detection count does **not** automatically indicate that a URL is safe.

Step 6 - Domain Investigation

Next, I investigated the sender domain - nextapp.pp.ua



The reputation lookup did not flag the domain as malicious.

Result

Clean

Instead of concluding that the email was safe, I correlated this result with all previous findings.

A clean domain reputation simply indicates that there is currently no known malicious reputation.

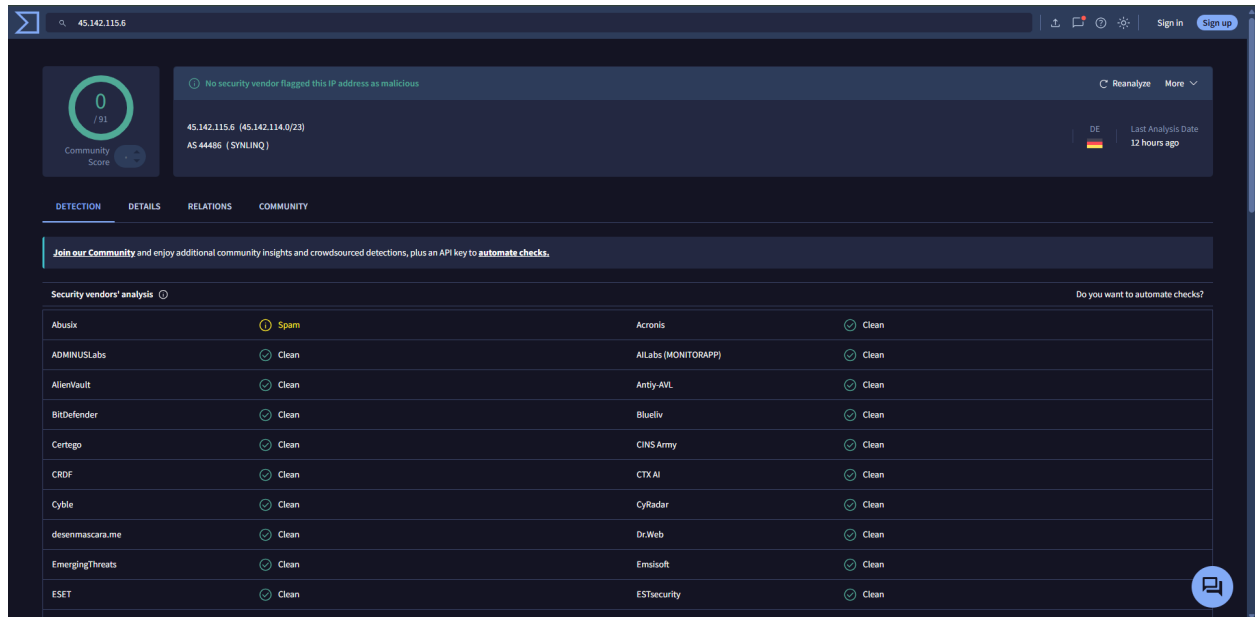
It does not prove legitimacy.

Step 7 - Sender IP Investigation

From the email headers, I extracted the sending IP address.

45.142.115.6

I investigated the IP using VirusTotal.



Result

Field	Value
Detection	0 / 92
Country	Germany
Status	HTTP 200 Response

No security vendor had flagged the IP at the time of analysis.

Again, this did not change my conclusion because IP reputation alone cannot determine whether an email is malicious.

SOC analysts correlate multiple sources of evidence before making a decision.

Indicators of Compromise (IOCs)

Type	Value
Subject	You have won a YETI PATRIOTIC Bundle
Display Name	Ace Hardware®
Sender Email	return@gnhmppgatace.nextapp.pp.ua
Return Path	18719-151503@648sd4f6hjk5y23.nextapp.pp.ua
Sender IP	45.142.115.6
URL	https://storage.googleapis.com/cocodrillo/thannina.html

Step 8 - Mapping the Findings to MITRE ATT&CK

Once I completed the technical analysis, I wanted to understand **which attacker techniques were being used** in this phishing campaign. Instead of selecting MITRE ATT&CK techniques first, I started by reviewing the evidence I had already collected during the investigation.

I asked myself a few simple questions:

- What is the attacker trying to achieve?
- Is the email trying to make the user click a link?
- Is it impersonating a trusted brand?
- Does the attack rely on the user taking an action?

Based on these observations, I visited the **MITRE ATT&CK** website and searched for the behaviors I had identified, such as "**Phishing**", "**Spearphishing Link**", "**User**

Execution", and **"Masquerading"**. I then read the description of each technique to confirm that it matched the evidence collected during my investigation.

Rather than mapping techniques based on assumptions, I used the investigation findings to identify the most appropriate ATT&CK techniques associated with this phishing email.

This approach helped me understand not only **what happened**, but also **how the attack aligns with known adversary behaviors** documented in the MITRE ATT&CK framework.

Observed Activity	MITRE ATT&CK Technique	Technique ID	URL
Phishing email claiming a reward	Phishing	T1566	https://attack.mitre.org/techniques/T1566/
Embedded "Claim Your Reward" button	Spearphishing Link	T1566.002	https://attack.mitre.org/techniques/T1566/002/
User encouraged to click the malicious link	User Execution	T1204	https://attack.mitre.org/techniques/T1204/
Impersonation of Ace Hardware	Masquerading	T1036	https://attack.mitre.org/techniques/T1036/

Step 9 - Mitigation & Recommendations

After confirming that the email was a phishing attempt, I documented a few recommendations that could help prevent users from falling victim to similar attacks.

1. Do Not Interact with Suspicious Emails

If an email claims that you have won a prize, requests urgent action, or asks for sensitive information, avoid clicking any links or downloading attachments until the sender has been verified.

2. Verify the Sender's Email Address

Instead of trusting the display name, always check the actual sender's email address and domain. In this investigation, the email claimed to be from **Ace Hardware**, but the sender's domain was unrelated to the organization.

3. Validate Embedded URLs Before Clicking

Hover over links to preview their destination. If the URL points to an unfamiliar domain or does not match the organization's official website, treat it as suspicious.

4. Review Email Authentication Results

When investigating suspicious emails, review SPF, DKIM, and DMARC results along with the email headers. Although SPF and DMARC passed in this case, DKIM failed, highlighting the importance of analyzing multiple authentication mechanisms rather than relying on a single result.

5. Correlate Multiple Indicators

A clean IP or domain reputation does not necessarily indicate that an email is legitimate. Decisions should be based on multiple indicators, including sender information, authentication results, URL reputation, email content, and threat intelligence.

6. Report Suspicious Emails

If an email is identified as phishing, report it using the email provider's phishing reporting feature or notify the organization's security team. Reporting suspicious emails helps improve detection and protects other users from similar attacks.

7. Block Malicious Indicators

Where appropriate, security teams can block or monitor the identified Indicators of Compromise (IOCs), such as:

- Sender email address
 - Sender domain
 - Malicious URLs
 - Sender IP address (after confirming malicious activity)
-

8. Improve User Awareness

Many phishing attacks rely on social engineering rather than technical vulnerabilities. Regular security awareness training can help users recognize common phishing tactics, including fake rewards, urgency, and brand impersonation.

Key Findings

- Gmail automatically classified the email as Spam.
 - The sender impersonated Ace Hardware using an unrelated domain.
 - DKIM authentication failed.
 - The email relied on reward-based social engineering.
 - The embedded URL was detected as phishing by multiple security vendors.
 - The sender IP and domain were not flagged by VirusTotal, highlighting the importance of correlating multiple indicators instead of relying on a single reputation check.
-

Final Conclusion

After correlating all the evidence, I classified the email as a **Phishing Attempt**.

The decision was based on multiple indicators rather than a single detection:

- Brand impersonation
- Suspicious sender domain
- DKIM failure
- Reward-based social engineering
- Gmail spam classification
- VirusTotal phishing detections for the embedded URL

Although the sender domain and IP did not have an established malicious reputation, the combined evidence provided sufficient confidence to identify the email as a phishing campaign.

Lessons Learned

This investigation reinforced an important lesson about phishing analysis.

A SOC analyst should never rely on a single indicator such as a VirusTotal score or domain reputation. Effective investigations require correlating email headers, authentication results, URL reputation, sender information, and social engineering techniques before concluding.

Working through this investigation helped me better understand how phishing emails are analyzed in real-world SOC environments and strengthened my ability to perform structured email triage and document findings in a professional incident report.